



Ezy Entregas

Plano de evolução: segurança, acesso biométrico e publicação na Play Store

Ordem recomendada: proteger dados e APIs → implementar autenticação → empacotar e publicar o aplicativo Android.

Etapa 1 — Segurança e banco de dados

- Retirar dados sensíveis do armazenamento local do navegador.
- Criar banco de dados centralizado, usuários, funções e permissões.
- Implementar sessões seguras, expiração de acesso e encerramento remoto.
- Proteger APIs com autenticação, validação, limite de requisições e tamanho de upload.
- Aplicar proteção contra abuso, injeção, scripts maliciosos e acesso indevido.
- Configurar logs de auditoria, backups e limites de gastos da OpenAI.
- Revisar tratamento de fotografias e dados pessoais conforme a LGPD.

Etapa 2 — Login por biometria

- Usar Passkeys/WebAuthn como mecanismo principal de autenticação.
- Permitir que o aparelho valide impressão digital, reconhecimento facial ou PIN.
- Não armazenar fotografias do rosto nem cópias de impressões digitais.
- Disponibilizar recuperação segura de conta e acesso alternativo autorizado.
- Registrar dispositivos e permitir que o administrador revogue acessos.

Etapa 3 — Aplicativo Android e Play Store

- Transformar o sistema em aplicativo Android com Capacitor.
- Configurar câmera, arquivos, biometria, ícone e tela de abertura.
- Testar funcionamento, desempenho, segurança e diferentes versões do Android.
- Gerar pacote Android App Bundle (AAB) assinado.
- Preparar política de privacidade, declaração de segurança dos dados e materiais da loja.
- Publicar primeiro em teste interno e, após validação, enviar para produção.

Etapa 4 — Comprovante digital e assinatura do recebedor

- Solicitar o nome completo da pessoa que recebeu a encomenda.
- Permitir selecionar o documento apresentado: CPF ou RG.
- Aplicar máscara automática ao CPF no formato 000.000.000-00.
- Aplicar máscara configurável ao RG, respeitando diferenças de formato entre os estados.
- Disponibilizar uma área para assinatura manuscrita diretamente na tela do celular ou tablet, usando toque ou caneta digital.
- Oferecer botões para limpar, refazer e confirmar a assinatura antes de concluir.
- Vincular o comprovante à encomenda, ao entregador, à data e ao horário da entrega.
- Exibir uma tela de conferência antes da gravação definitiva.

Recebedor	Nome completo obrigatório.
Documento	CPF ou RG com validação e máscara visual.
Assinatura	Traço capturado na tela sensível ao toque.
Entrega	Código da encomenda, data, horário e responsável pela operação.
Comprovante	Consulta posterior e inclusão opcional no relatório de entrega.

- Criptografar documento e assinatura durante transmissão e armazenamento.
- Mostrar o documento parcialmente oculto nas consultas, por exemplo ***.***.***-09.
- Restringir a visualização completa a usuários autorizados.
- Registrar quem consultou ou alterou o comprovante.
- Definir prazo de retenção e procedimento de exclusão conforme a LGPD.
- Não tratar a assinatura desenhada como autenticação biométrica do usuário.

Arquitetura recomendada

Componente	Recomendação
Frontend	Aplicação atual adaptada para PWA e Capacitor
Backend	Cloudflare Functions/Workers
Banco de dados	Cloudflare D1
Autenticação	Passkeys/WebAuthn com sessões seguras
Aplicativo Android	Capacitor com geração de arquivo AAB
Comprovante de entrega	Nome, CPF ou RG mascarado e assinatura por toque

Decisão inicial: confirmar o uso do Cloudflare D1 para armazenar usuários e entregas. Com essa definição, o desenvolvimento pode começar pela auditoria e proteção de segurança.